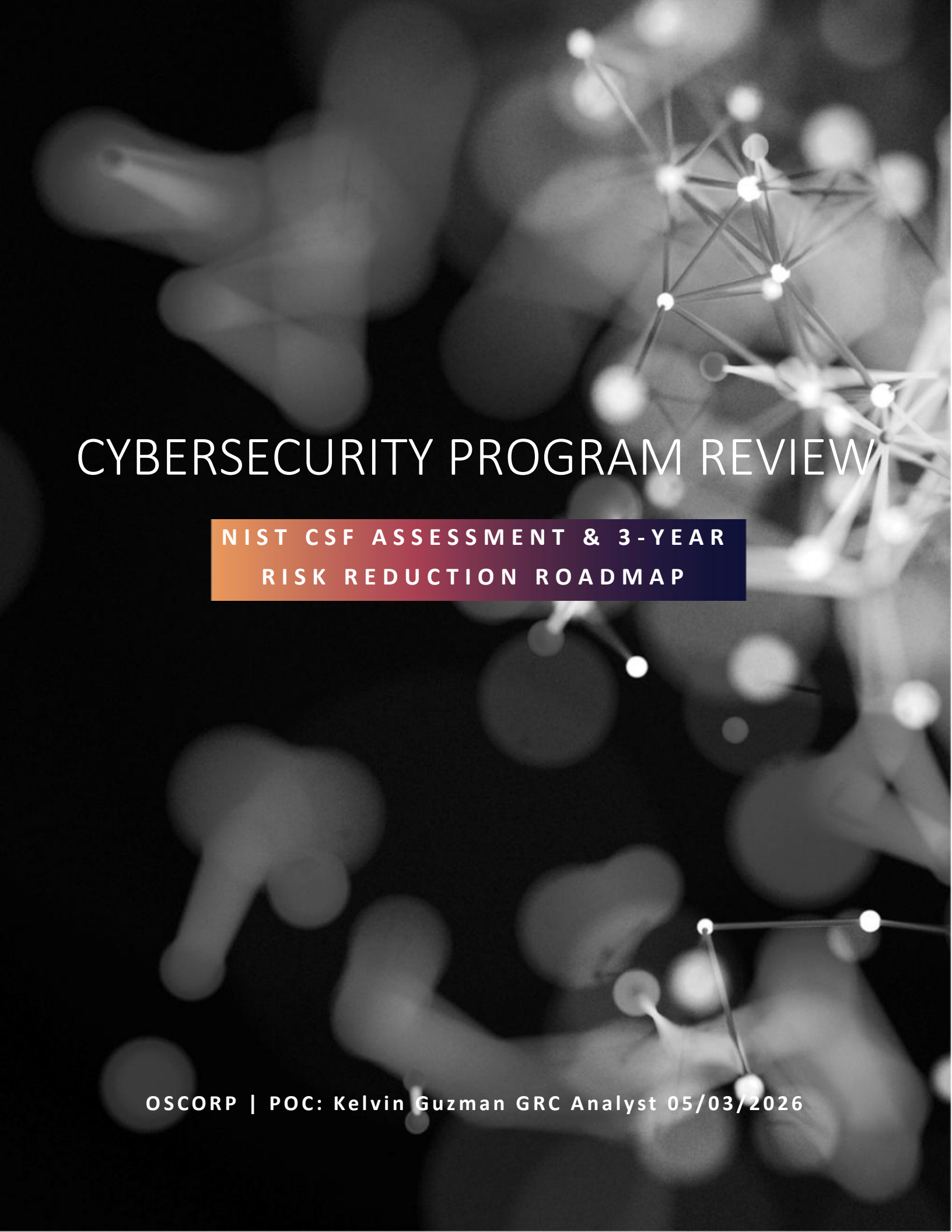




CYBERSECURITY PROGRAM REVIEW

NIST CSF ASSESSMENT & 3-YEAR
RISK REDUCTION ROADMAP

OSCOP | POC: Kelvin Guzman GRC Analyst 05/03/2026



EXECUTIVE SUMMARY

Oscorp operates in a high-risk environment due to its reliance on proprietary scientific research, specifically the drug formula that represents a critical revenue-generating asset. A cybersecurity assessment aligned to the [National Institute of Standards and Technology Cybersecurity Framework](#) identified material control gaps across identity and access management, data protection, detection and response, and third-party risk management. Current capabilities are largely reactive, with no formal cybersecurity strategy or enterprise risk integration.

Financial risk was quantified using a standard Annualized Loss Expectancy (ALE) model, supported by principles from Factor Analysis of Information Risk (FAIR) to refine likelihood and impact assumptions. Based on industry benchmark data (e.g., breach trends involving credential compromise and weak access controls), Oscorp's annual breach likelihood is estimated at 25%–35% in its current state. Impact estimates, driven primarily by potential loss of intellectual property, are conservatively modeled between \$50M and \$500M. This results in an estimated annualized cyber risk exposure of approximately \$15M–\$150M.



A structured 3-year cybersecurity program is recommended to reduce both breach likelihood and impact. Year 1 focuses on foundational risk reduction (multi-factor authentication, privileged access control, data loss prevention, centralized logging). Year 2 builds operational maturity (privileged access management, asset visibility, third-party risk management). Year 3 focuses on optimization (insider threat detection, continuous monitoring, and advanced risk quantification). Total program investment is estimated at \$0.75M–\$1.5M over three years, based on comparable enterprise implementations.

Control effectiveness assumptions derived from industry studies indicate that implementation of these measures can reduce breach likelihood by approximately 60%–70% within the first year. This translates to a conservative annual risk reduction of \$9M–\$95M.

Using a standard return-on-investment model, the program delivers an estimated return of approximately 8x under conservative assumptions, with significantly higher returns under high-impact scenarios involving intellectual property compromise.

In summary, Oscorp’s current cybersecurity posture represents a measurable and avoidable business risk. The proposed program is financially justified, aligned with protecting core intellectual property, and necessary to transition cybersecurity from an ad hoc IT function into a structured enterprise risk management capability.



CURRENT STATE ASSESSMENT

GOVERNANCE & RISK

Oscorp currently lacks a formal cybersecurity governance structure and enterprise risk alignment. Cybersecurity responsibilities are informally assigned to the IT function, with no defined ownership, accountability, or reporting structure at the executive level. There is no documented cybersecurity strategy, and cyber risk is not integrated into the broader enterprise risk management framework.

While a financial risk function exists, it does not extend to technology or information security risks. As a result, cyber threats are not quantified, prioritized, or tracked in a structured manner. This creates a gap in executive visibility and limits the organization's ability to make informed, risk-based investment decisions.

IDENTITY & ACCESS MANAGEMENT

Identity and access management controls present a significant risk exposure. Oscorp does not enforce multi-factor authentication, and privileged access is not formally managed. Administrative credentials are shared among members of the IT team, creating a lack of accountability and increasing the risk of unauthorized access.

Access to systems and data is granted on an ad hoc basis without a standardized approval or review process. There is no implementation of least privilege principles or periodic access certification. These weaknesses significantly increase the likelihood of credential compromise and unauthorized access to sensitive systems, including those containing proprietary research data.

DATA SECURITY

Oscorp does not have a formal data security or data governance framework in place. There is no classification scheme to distinguish between standard and sensitive data, including high-value intellectual property such as drug research and formula-related information.

Additionally, there are no Data Loss Prevention (DLP) controls implemented across the Microsoft 365 and Azure environment. This results in a lack of visibility and control over how sensitive data is accessed, shared, or transmitted. Given the organization's reliance on proprietary research, this represents a material risk of data exfiltration and intellectual property loss.

DETECTION & RESPONSE

Oscorp does not have a centralized detection and response capability. There is no Security Information and Event Management (SIEM) solution in place, and logging is not aggregated or actively monitored across systems.

Incident response is reactive and limited to responding to alerts generated by endpoint protection tools. There is no formal incident response plan or defined escalation process for engaging senior leadership during a cyber event. This lack of visibility and coordination increases the likelihood that security incidents will go undetected or be identified too late, amplifying potential business impact.

VULNERABILITY MANAGEMENT

While Oscorp has invested in a vulnerability scanning tool (Qualys), its use is inconsistent and not supported by a formal vulnerability management program. Scans are conducted on an ad hoc basis, and there are no defined remediation timelines or accountability mechanisms.

As a result, a significant number of high and critical vulnerabilities remain unresolved across end-user systems. The absence of structured patch management, prioritization based on risk, and remediation tracking increases the organization's exposure to exploitation and serves as a likely entry point for attackers.



Figure 1



CYBERSECURITY BUSINESS PRIORITIES

- Protect proprietary research and drug formula
- Reduce likelihood of credential-based breaches and unauthorized access
- Establish enterprise-wide visibility across systems and data
- Align cybersecurity with business risk and financial exposure
- Enable secure growth of cloud and SaaS operations



ADDED PRIORITIES

- Strengthen third-party risk oversight (critical SaaS dependencies)
- Improve incident response readiness and executive engagement
- Reduce operational inefficiencies caused by reactive security practices

3-YEAR CYBERSECURITY ROADMAP

YEAR - 1 RISK CONTAINMENT

Year 1 focuses on addressing the highest risk control deficiencies that directly contribute to breach likelihood and potential intellectual property exposure. Priority is placed on identity security, data protection, and visibility.

Key initiatives include enforcing multi-factor authentication across all users, eliminating shared administrative credentials, and implementing baseline privileged access controls.

Data protection capabilities will be established through deployment of Data Loss Prevention (DLP) controls and classification of sensitive research data. In parallel, Oscorp will implement centralized logging and monitoring through a SIEM platform to establish visibility into user and system activity. A formal vulnerability management program will also be introduced, including defined patching service-level agreements and remediation tracking.

The outcome is immediate reduction in breach likelihood driven by improved access control, reduced attack surface, and increased detection capability.

YEAR - 2 MATURITY

Year 2 focuses on building operational consistency and strengthening control effectiveness across the environment. This phase transitions cybersecurity from reactive controls to structured processes.

Key initiatives include implementation of a full Privileged Access Management (PAM) solution, automation of identity lifecycle management (joiner-mover-leaver processes), and deployment of a centralized Configuration Management Database (CMDB) with automated asset discovery.

Additionally, Oscorp will establish a formal Third-Party Risk Management (TPRM) program to assess and monitor vendor security posture, particularly for critical SaaS providers. Incident response capabilities will be formalized and tested through structured exercises involving both technical teams and executive stakeholders.

The outcome is reduced operational risk, improved control consistency, and stronger oversight of internal and external risk factors. Additionally, recovery capabilities will be formalized and tested, including periodic validation of data restoration procedures and business continuity effectiveness.



Y E A R - 3 O P T I M I Z A T I O N

Year 3 focuses on advanced capabilities and long-term resilience, aligning cybersecurity with strategic business objectives and enterprise risk management.

Key initiatives include implementation of insider threat detection capabilities using behavioral analytics, continuous control monitoring to validate effectiveness of key controls, and adoption of advanced risk quantification methods to support financial decision-making.

Oscorp will also begin aligning its architecture with Zero Trust principles, enforcing conditional access policies based on identity, device health, and user behavior.

The outcome is that Cybersecurity becomes a proactive, intelligence-driven function that supports business growth while maintaining strong protection of critical assets. A continuous improvement cycle will be established, incorporating control testing, audit findings, and post-incident lessons learned to ensure ongoing program effectiveness.

F U T U R E S T A T E V I S I O N

Beyond the initial 3-year roadmap, Oscorp's cybersecurity program should evolve into a fully integrated, intelligence driven capability aligned with enterprise risk management and business strategy.

Future priorities include advancing toward continuous, real-time risk quantification to support executive decision making, further maturing Zero Trust architecture across all systems, and expanding automation within security operations to improve efficiency and response speed.

Additionally, cybersecurity should be embedded into business processes, including product development, vendor onboarding, and strategic planning, ensuring that security is treated as a core business function rather than a supporting IT capability.

Over time, this approach positions Oscorp to proactively manage cyber risk, adapt to evolving threats, and sustain long term protection of critical intellectual property and business operations.



CYBER DEFENSE ROI

Oscorp's cybersecurity investment has been evaluated using a structured financial risk model to quantify both current exposure and expected risk reduction. The analysis is based on the Annualized Loss Expectancy (ALE) model, with refinement using principles from the Factor Analysis of Information Risk (FAIR) framework to ensure defensible assumptions.

RISK QUANTIFICATION METHODOLOGY

Cyber risk exposure is calculated using the standard formula:

$$\text{Annualized Loss Expectancy (ALE)} = \text{Likelihood of Event} \times \text{Impact per Event}$$

Likelihood Estimation:

Baseline breach likelihood is derived from industry data, including:

- Verizon Data Breach Investigations Report ([DBIR](#)), which indicates that a significant proportion of breaches involve credential compromise and weak identity controls
- [IBM Cost of a Data Breach Report](#), which provides frequency and lifecycle insights

Industry average breach likelihood for organizations of similar size is estimated at 15%–20% annually.

Oscorp's likelihood is adjusted upward to 25%–35% based on identified control deficiencies:

- Absence of multi-factor authentication
- Shared administrative credentials
- Lack of centralized monitoring and detection

These conditions increase the probability of successful exploitation per threat event.

IMPACT ASSUMPTIONS

Financial impact estimates are based on industry breach cost data from IBM Cost of a Data Breach Report and adjusted for Oscorp's dependency on proprietary research.

- Industry average breach cost: ~\$4.45M
- Oscorp adjustment factors:
 - High-value intellectual property (drug formula)
 - Revenue dependency on proprietary research
 - Competitive and legal exposure

As a result, potential impact is modeled as:

- Conservative scenario: \$50M
- High-impact scenario: \$500M

This range reflects loss scenarios involving intellectual property exposure, including competitive disadvantage and loss of market exclusivity.



CURRENT RISK EXPOSURE

Using the ALE model:

- Conservative scenario:
 $0.30 \times 50M = 15M$
- High-impact scenario:
 $0.30 \times 500M = 150M$

Estimated annual cyber risk exposure: \$15M–\$150M

RISK REDUCTION THROUGH CONTROL IMPLEMENTATION

The proposed cybersecurity program reduces risk by lowering both breach likelihood and impact. Estimated control effectiveness is based on aggregated industry findings:

- Multi-factor authentication: reduces credential-based attacks by ~50%
- Privileged access controls: reduces privilege misuse risk by ~20–30%
- Data Loss Prevention: reduces data exfiltration risk by ~30–40%
- Centralized monitoring (SIEM): reduces detection time by ~40–60%

These controls are not additive; their combined effect is conservatively estimated to reduce breach likelihood by: 60%–70%

POST-IMPLEMENTATION RISK EXPOSURE

Adjusted likelihood:

$$30\% \times (1 - 0.65) \approx 10\% - 12\%$$

Updated ALE:

- Conservative:
 $0.11 \times 50M = 5.5M$
- High-impact:
 $0.11 \times 500M = 55M$

ANNUAL RISK REDUCTION VALUE

- Conservative:
 $15M - 5.5M = 9.5M$
- High-impact:
 $150M - 55M = 95M$

PROGRAM INVESTMENT

Estimated 3-year investment is based on typical enterprise cybersecurity program costs within Microsoft-centric environments:

- Identity and access controls
- Data protection (DLP)
- SIEM and monitoring
- Security operations and response
- Third-party risk management

Total estimated investment: \$0.75M–\$1.5M over 3 years



RETURN ON INVESTMENT (ROI)

ROI is calculated as:

$$\text{ROI} = \frac{\text{Risk Reduction} - \text{Cost}}{\text{Cost}}$$

- Conservative scenario:

$$\frac{9.5M - 1M}{1M} = 8.5x$$

- High-impact scenario:

$$\frac{95M - 1M}{1M} = 94x$$

FINAL ROI DETERMINATION

Based on the modeled scenarios, the cybersecurity program delivers a definitive positive return on investment under all conditions evaluated.

Conservative Case

- Annual risk reduction: \$9.5M
- Program cost (annualized): ~\$1M

High-Impact Case (IP Loss Scenario)

- Annual risk reduction: \$95M
- Program cost (annualized): ~\$1M

Across all modeled scenarios, the program delivers:

- Minimum ROI: ~8x (850%)
- Expected ROI range: 8x – 94x
- Payback period: < 12 months

CONCLUSION

The proposed cybersecurity program represents a financially justified investment, with projected returns significantly exceeding implementation costs. The analysis demonstrates that relatively modest investment in foundational and advanced security controls can materially reduce Oscorp's exposure to high-impact cyber events.

From a business perspective, the program directly protects revenue-generating intellectual property, reduces operational disruption risk, and improves the organization's overall risk posture.

Failure to implement these controls would leave Oscorp exposed to a level of financial risk that is disproportionate to the cost of mitigation.

NIST CSF ASSESSMENT SUMMARY

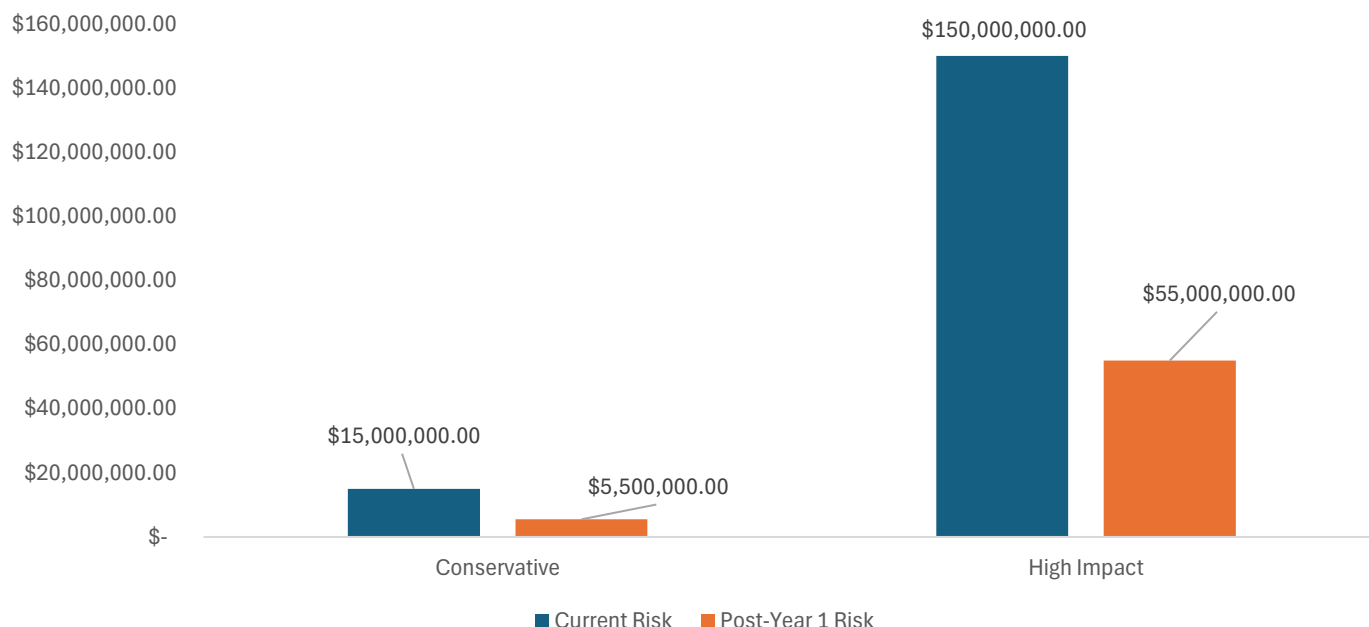
Function	Maturity	Gap
Govern	Low	No strategy
Identify	Low	Weak asset management
Protect	Medium-Low	No MFA/DLP
Detect	Low	No SIEM
Respond	Low	No IR process
Recover	Medium	Strong BCP

FINAL RECOMMENDATION

Oscorp should proceed with the proposed cybersecurity program as it directly reduces material financial risk associated with intellectual property loss, data breaches, and operational disruption. The program also establishes ongoing validation and continuous improvement mechanisms to ensure long-term effectiveness and adaptability to evolving threats. The investment is justified based on industry benchmark data and modeled risk reduction, positioning cybersecurity as a risk mitigation function rather than a cost center.

~60–70% reduction in breach likelihood after Year 1 controls

Annual Cyber Risk Exposure Reduction



APPENDIX A — SOURCES & ASSUMPTIONS

METHODOLOGY

Financial risk estimates are based on the standard model:

$$\text{ALE} = \text{Likelihood} \times \text{Impact}$$

Estimates are refined using principles from the FAIR framework (threat frequency, vulnerability, and loss magnitude).

DATA SOURCES

- IBM Cost of a Data Breach Report (average breach cost baseline)
- Verizon DBIR (breach likelihood and attack trends)

KEY ASSUMPTIONS

Likelihood

- Industry baseline: 15%–20% annually
- Adjusted for Oscorp (no MFA, shared admin, no monitoring):
25%–35% annual breach probability

IMPACT

- Baseline breach cost: ~\$4.45M (IBM)
- Adjusted for high-value IP exposure:
\$50M–\$500M impact range

CONTROL EFFECTIVENESS

- MFA: ~50% risk reduction (credential attacks)
- PAM: ~20–30% reduction (privilege misuse)
- DLP: ~30–40% reduction (data exfiltration)
- SIEM: ~40–60% faster detection

Combined effect (non-additive): ~60%–70% likelihood reduction

INVESTMENT

- Estimated program cost:
\$0.75M–\$1.5M over 3 years

SUMMARY

All estimates are derived from industry benchmark data and adjusted to reflect Oscorp's control gaps and reliance on high-value intellectual property.